TECHPRIME AI · CAPSTONE DEFENSE

Panel Questions Cheat Sheet

Short answers you can say out loud. Each one is based on the actual code. The full explanations are in the System Guide.

5 roles
Admin, Retail Officer, Inventory Custodian, Cashier, Client

3 AI models
XGBoost (forecast), SVM (Primo), Random Forest (Build a PC)

83.8%
Primo on 160 unseen hard sentences (134/160)

82.7% ± 1.7
Primo 5×5 cross-validation, 922 examples

0.32
Primo confidence threshold → below it, ask to rephrase

16 intents
price, stock, order status, compatibility, greeting…

99.0%
Random Forest accuracy, 4-fold CV grouped by build

65% vs 57%
Hit@3 on real builds: model vs rules (price 51%, random 40%)

60 trees · 23 features
54,724 training rows (53,985 rule + 739 real)

1–3 months
Forecast horizon (demand + revenue)

0 · 1–5 · 6–15
Out · Critical · Low stock thresholds

3 tries · 15 min
Lockout after 3 wrong passwords · idle logout

12% VAT
Prices VAT-inclusive: VAT = total − total ÷ 1.12

261 products
Imported from EasyPC's Oasis item list

24 h · 90 d · 7 d
Activation link · unanswered log · Primo chat history

02:00 nightly
Build-a-PC retrain, goes live only if accuracy ≥ 0.90

Answer shape: what it does → how it works → how you know it works (a test or a number).

Don't know? "That part is handled by ___; I can show it in the code." Then open the file named under the answer.

Limitation asked? Admit it, give the reason (scope/time), give the fix. Admitting it plainly scores better than defending it.

TRAP a question meant to catch a weak spot · ADMIT a known limitation · DEEP a technical follow-up

1 · The project in general — opening questions

Q Explain your system in one minute.
TechPrime AI is an inventory, point-of-sale and online-store system for EasyPC One Oasis. A single database connects the counter, the stock room, the website and the office. A counter sale, an online order and a supplier delivery all update the same stock number immediately. Three AI features sit on top: demand and sales forecasting, the Primo chatbot, and a Build-a-PC recommender.

Q What problem does it solve?
Stock that drifts out of sync between counter and records, items running out without warning, no online channel, and buying decisions based on guesses. We answer with live stock, automatic low-stock alerts, an online store, and forecasts with reorder suggestions.

Q Who are the users?
Five roles. Clients (customers) shop online. Cashiers sell at the counter. Inventory Custodians manage products, stock-in and online orders. Retail Officers handle reports and forecasts. Admins handle accounts, logs and settings.

Q What makes it "AI"?
Three trained models. XGBoost forecasts demand and revenue. An SVM classifies what a chat message is asking for. A Random Forest ranks compatible PC parts. Each one was evaluated with held-out data (see the numbers above).

Q What is the scope? What is NOT included?
Included: one branch's inventory, POS, online orders (delivery via Lalamove or store pickup), reports, forecasts, chatbot and PC builder. Not included: multi-branch stock, a real payment gateway, accounting/payroll, and courier tracking integration.

Q What is new compared with existing systems?
Forecasts that turn into inventory actions (reorder point, order quantity). A chatbot that answers from live store data in Taglish. A PC builder that combines hard compatibility rules with a model trained on real customer builds. All on one shared stock database.

Q Did the client actually use or validate it?
The catalog is EasyPC's real item list (261 products, their SKUs and barcodes). *Add your own evaluation or acceptance results here if you ran a user survey or client test.*

Q Why the name “TechPrime AI”? Why “Primo”?
Answer from your team. Primo is the store's shopping assistant persona.

2 · Technology and architecture

Q What is your tech stack?
PHP 8.2 on Apache with vanilla JavaScript/CSS and a PostgreSQL database on Supabase. Python (scikit-learn, Flask) for the chatbot and PC models, and an XGBoost forecast service on Render. Gmail SMTP sends e-mails, and Chart.js draws the charts.

Q Your proposal said Next.js / FastAPI. Why PHP?
TRAP
Plain PHP runs on XAMPP and simple hosting with no build step, which fit our timeline. We kept Python where it matters, for the ML. PostgreSQL was chosen because the POS needs real transactions and row locks.

Q Why PostgreSQL and not MySQL?
We needed reliable transactions, `SELECT … FOR UPDATE` row locks, `RETURNING`, CHECK constraints (stock ≥ 0) and a hosted, backed-up service (Supabase).

Q Why no framework (Laravel, React)?
The pages are server-rendered, which keeps them fast and simple to deploy with no build step. Shared helpers in `includes/` give us the reuse a framework would.

Q How does the browser talk to the AI models?
It never does directly. The browser calls PHP, and PHP calls the Python services. That keeps API keys secret and lets PHP validate input, check the user's role and rate-limit.
backend/api/primo_chat.php · forecast_api.php

Q Where is it hosted?
Locally on XAMPP. For hosting, a Docker image (`php:8.2-apache`, Asia/Manila timezone). The database is on Supabase; Primo and the forecast service run on Render.

Q How do you keep passwords and API keys out of the code?
They live in a `.env` file or in server environment variables, loaded with phpdotenv, and never committed to Git.

Q Is it responsive / mobile-friendly?
Yes. Staff screens have a sidebar on desktop and a bottom tab bar on phones, and tables turn into cards on small screens. Buttons are at least 44 px, and status is shown with an icon and text, not colour alone.

3 · Security and access control

Q How are passwords stored?
As bcrypt hashes (`password_hash`). We never store or see the real password; login uses `password_verify`.

Q What stops brute-force login?
Three wrong passwords lock the account (`is_locked`), which is recorded in `locked_accounts` and the audit log. Only an Admin can unblock it.
login.php

Q Admin Settings has “max failed attempts”. Does it work?

ADMIT

The value is saved, but login currently uses a fixed 3. Connecting it is a one-line follow-up in `login.php`.

Q Can a cashier open the admin page by typing its URL?

No. Every page starts with `checkRole()`, which redirects to login. JSON endpoints check the session role and return 403.

Q What about SQL injection?

All queries use PDO prepared statements, so user input is sent as data, never as SQL.

Q And XSS?

Every value printed into HTML goes through `h()` (`htmlspecialchars`), so typed scripts show as text.

Q What is CSRF and how do you prevent it?

A forged form submitted from another site. Each form carries a random secret token stored in the session, and the server compares it with `hash_equals` before doing anything.

Q What if a staff member leaves the PC unattended?

After 15 minutes of inactivity the session ends; a 60-second countdown warning appears first. Background polling (stock alerts) doesn't count as activity.

Q How do you verify customer e-mails?

An activation link with a random 64-character token that expires in 24 hours. It works once (the token is deleted), and a resend option is offered.

Q Do you have two-factor authentication?

ADMIT

TOTP (Google Authenticator) code exists in the older API (`backend/api/auth.php`), but the main login page doesn't use it yet. Adding it for staff accounts is the next step.

Q Why does login say “Invalid email or password” for both cases?

So an attacker can't find out which e-mails have accounts.

Q How can you trace who did something?

`logActivity()` records the user, action, details (for example “stock 3 → 23”) and IP for logins, sales, stock-ins, orders, exports and settings changes. Admin sees it in Activity Logs.

Q Could someone read the database through Supabase's public API?

DEEP

No. Row Level Security is on with no policies, so the public REST API returns nothing. Only our server's connection reads data.

Q What is session fixation and do you handle it?

DEEP

An attacker plants a session ID before login. We call `session_regenerate_id(true)` on login, so the planted ID becomes useless.

4 · Cashier POS

Q Walk us through a POS sale.

Scan → the check digit is validated → the product is looked up → added to the cart. Then choose Cash, GCash, Maya or Card, complete the sale (one database transaction), and print the receipt with an invoice number like `INV-20261023-000123`.

Q How does the scanner work without clicking a field?

A USB scanner types like a very fast keyboard and ends with Enter. `barcode_scanner.js` detects keystrokes arriving milliseconds apart and treats them as a scan.

Q What if the barcode is misread?

The last digit is a check digit computed from the others (weights 1 and 3, then mod 10). One wrong digit breaks the check, and the scan is rejected in both the browser and the server.

Q Two cashiers sell the last item at the same time. What happens?

TRAP

The sale locks the product rows (`FOR UPDATE`). The second sale waits, then sees stock 0 and gets “Not enough stock”. The update also requires `stock >= qty`, and the database forbids negative stock.

Q What if the cashier clicks “Complete sale” twice or Wi-Fi drops?

Each sale carries a unique ID (UUID, `client_ref`) created by the screen. A repeat request returns the original sale instead of charging twice. The UNIQUE constraint also covers two requests arriving at the same instant.

Q What if something fails halfway through a sale?

Everything is in one transaction: sale, items, stock deduction, stock movement and log. Any error rolls all of it back: “No changes were saved.”

Q Can someone change a price in the browser?

No. The server ignores browser prices and reads them from the database inside the transaction. If prices changed since the scan, the cashier is asked to review the new total.

Q How is VAT computed?

Prices include 12% VAT. VATable = total ÷ 1.12 (rounded to the centavo); VAT = total − VATable, so the two always add up exactly. Example: ₱3,450.00 → ₱3,080.36 + ₱369.64.

Q Why store money as centavos?

DEEP

Decimal fractions like 0.1 aren't exact in floating point, so the POS works in whole centavos (₱1,234.50 = 123450) to keep totals and change exact.

Q What is a deadlock and how do you avoid it?

DEEP

Two sales each waiting for a row the other locked. We always lock products in ID order, so the circular wait can't happen.

Q Can the cashier add stock?

No, by design. Stock-in belongs to the Inventory Custodian (separation of duties), so the person handling cash can't also adjust stock to hide shortages.

Q Is GCash/Maya/Card payment integrated?

ADMIT

At the counter the customer pays on their own app or terminal, and the cashier records the reference number (required). There is no direct API integration.

5 · Online store and orders

Q What are the order statuses?

To Pay → To Ship → To Receive (“With Courier”) → Completed, or Cancelled. Status only moves forward; Completed and Cancelled are final. Pickup orders skip To Ship.

Q When is stock deducted for online orders?

TRAP

Stock is checked (with a row lock) when the order is placed, and deducted once, when the customer clicks “Item Received” or staff completes the order. Unpaid orders can still be cancelled, so deducting earlier would show items as sold out when they aren't. A `stock_deducted` flag guarantees it happens only once.

Q Then can two customers order the last item?

TRAP

Both orders can be placed, because stock isn't reserved at order time. Completion deducts with `stock >= qty`, so the second completion is refused rather than going negative. A reservation step at payment is a possible improvement.

Q Is the online payment real?

ADMIT

No. It's a placeholder for the project; the page says so. “Pay Now” marks the order paid with a generated reference. A real gateway (for example PayMongo) would replace only that step.

Q Who can cancel, and when?

The customer can request it only while the order is unpaid and in To Pay, choosing a reason. The custodian approves it. Stock doesn't change because none was deducted.

Q What happens to a guest's cart after login?

It merges into the saved database cart (keeping the higher quantity for duplicates), so carts survive logout and login.

Q What stops a double order from a double-click?

A one-time checkout token: the second submit is refused.

Q How is delivery handled?
Delivery orders get a shipment record with carrier Lalamove; the custodian updates the status. Pickup orders become To Receive right after payment.

Q Can customers leave reviews?
One review per completed order: 1–5 stars, comment, tags, optional photos, and it can be anonymous. The custodian can reply.

Q How does the customer know what's happening?
Bell notifications at each step (placed, paid, accepted, completed, cancellation), each linking to the right order tab.

6 · Inventory, reports and admin

Q How do stock alerts work?
Out = 0, Critical = 1–5, Low = 6–15. After every stock change, the system compares the old and new level and notifies Admin, Retail Officer and Custodian only when the level changes (or stock recovers). The same alert isn't repeated within 24 hours.

Q Why fixed thresholds for all products?
ADMIT
It keeps the rule simple and clear for the store. A per-product reorder level, or using the forecast's reorder point, is the improvement.

Q How is a delivery from a supplier recorded?
Stock-in: scan, quantity (1–10,000), supplier (required) and reference number. It locks the row, adds the stock, and writes a `stock_movements` entry (before → after) plus an audit log line.

Q Where is your suppliers table?
TRAP
There isn't one. A supplier is the product's brand, matched from the first word of the product name against the shop's brand list. Simple for this branch; a real suppliers table is future work.

Q What if a product has no barcode?
The custodian generates an in-store EAN-13: “21” + 10-digit product ID + check digit, and prints a label.

Q What counts as a sale in reports?
Completed online orders plus POS sales. Unpaid, in-transit and cancelled orders don't count. Reports read live data.

Q What reports can the Retail Officer produce?
Totals, transactions, units, average sale, sales by category, daily trend and a 12-month breakdown, with month-over-month and year-over-year % badges. Exports to CSV, Excel and PDF, and each export is logged.

Q What can the Admin do?
Create staff accounts, block/unblock/delete users, view all activity logs, set the password policy, and view alerts, forecasts and messages.

Q How is time handled?
DEEP
Timestamps are stored in UTC and displayed in Asia/Manila time, so “today's sales” is correct wherever the server runs.

Q Is there internal communication?
Staff chat for Admin, Retail and Custodian: attachments, reactions, unsend, forward, pin and search, plus a floating widget on every staff page. Each action checks that the user is in that conversation.

7 · AI #1 · Forecasting (XGBoost)

Q What does the forecast predict?
Units per product (demand) and store revenue for 1, 2 or 3 months ahead. Each comes with a likely range, the trend, confidence, and inventory actions: days of stock left, safety stock, reorder point, stockout risk and a recommended order quantity.

Q What is XGBoost, simply?
Many small decision trees built one after another. Each new tree corrects the errors of the previous ones, and the forecast is the sum of all of them (“gradient boosting”). It works well on tabular sales data.

Q Why XGBoost and not ARIMA or linear regression?

DEEP

Sales per product are irregular and depend on several factors (recent months, trend, category). Boosted trees handle many features and non-linear patterns without assuming a fixed curve, and they train fast on small tabular data.

Q What is a reorder point?

The stock level at which to order: average daily demand × supplier lead time + safety stock. Example: 2/day × 7 days + 6 = 20.

Q What is safety stock?

Extra units kept for unexpected demand or late deliveries, so the store doesn't run out while waiting for stock.

Q Why does the forecast sometimes load slowly?

The service is on Render's free tier, which sleeps when idle and can take about 50 seconds to wake. The proxy waits up to 75 seconds, and the screen asks the user to retry if it's still waking.

Q How is the forecast API protected?

Only Admin, Retail and Custodian can call it (403 for others). PHP adds the API key server-side, validates the horizon (1–3), category text and dates, and requires HTTPS.

Q How accurate is the forecast?

ADMIT

The screen shows each product's confidence and model reliability from the service's metrics. *Quote the accuracy figure (MAE/MAPE/WAPE) from your forecast service's evaluation; it's in the forecast repository, not this codebase.*

Q Where is the model code?

In a separate repository deployed to Render. This system uses it through `forecast_api.php` and displays it in `includes/forecast_cards.php`.

Q What if there is little sales history?

TRAP

Forecasts are less reliable for new or rarely sold products; that's why the screen shows a confidence and a likely range, not just one number.

8 · AI #2 · Primo chatbot (TF-IDF + SVM)

Q How does Primo understand a question?

TF-IDF turns the text into numbers (words, word pairs and 3–5-letter chunks). An SVM then picks one of 16 intents with a confidence. PHP runs that intent's handler, which reads the live database.

Q What is TF-IDF?

Term frequency × inverse document frequency: words that are distinctive across all examples weigh more than common words like “the”.

Q What is an SVM?

A Support Vector Machine learns the boundaries that best separate the categories. We use an RBF kernel (C = 2.5, balanced classes) with probability outputs.

Q Why SVM and not a neural network or only ChatGPT?

TRAP

With about 900 examples, an SVM is accurate, fast, explainable and runs on a free server. An LLM alone could invent prices or stock. Here the model only chooses the intent; the facts come from our database.

Q How does it handle Taglish and typos?

Character chunks: “magkano”, “mgkano” and “magkanoo” share most 3–5-letter pieces. The training data also has 102 Taglish/Filipino examples.

Q What if Primo is unsure?

If the top probability is below 0.32, it asks the shopper to rephrase instead of guessing, and saves the masked question so we can retrain on it.

Q How did you pick 0.32?

DEEP

With `tune_threshold.py` on out-of-fold probabilities. Macro-F1 was almost flat from 0.10 to 0.32, so we took the highest threshold within 0.005 of the best. That's about 8% wrong answers and 9% rephrase requests.

Q How do you know the 83.8% is honest?

The 160-sentence hard test set was written before the new training data and is never trained on. Training rows that were too similar to a test sentence (cosine ≥ 0.80) were removed.

Q Then what is the LLM (Groq) for?
Only to rephrase our database sentence so it sounds friendlier, and for small talk about the shop. If any peso amount, product name or “N on hand” changes, the reply is rejected and the original sentence is used.

Q Can Primo answer off-topic questions (homework, love advice)?
No. Off-topic messages get a fixed “I'm only here for EasyPC” reply and are never sent to the LLM.

Q What about privacy (Data Privacy Act, RA 10173)?
E-mails and phone numbers are masked before anything goes to Groq or the unanswered log. That log has no user, session or IP and is deleted after 90 days. Chat history is deleted after 7 days, and the privacy policy page explains all of it.

Q Can someone spam Primo?
Rate limits: 15 messages per minute per browser and 60 per IP. Messages are capped at 400 characters, and CSRF is checked.

Q What are Primo's weak spots?
ADMIT
The “help” and “fallback” intents (4–6 out of 10 on the hard set). The test set was written by the same team, so the next round of data will come from real unanswered questions.

Q Can it answer “Will this GPU fit my case?”
Yes. Compatibility questions skip the SVM and use the same rules as Build a PC.

9 · AI #3 · Build a PC (rules + Random Forest)

Q How does it check compatibility?
It reads tags from product names and descriptions: socket, DDR type, form factor, NVMe/SATA, watts. Rules then check CPU socket = board socket, RAM type = board/CPU type, cooler socket, case ≥ board size and PSU ≥ estimated draw.

Q Then why do you need machine learning?
TRAP
Rules only say what fits. Among compatible parts, the forest ranks what suits this purpose, budget and the rest of the build. On real customer builds it put the chosen part in the top 3 65% of the time, versus 57% for rules alone, 51% for price range and 40% for random.

Q What is a Random Forest?
60 decision trees, each trained on a random sample. Each one votes a “good fit” probability; we average them. A score ≥ 0.5 means a good fit, and the top 3 get the Recommended badge.

Q What features does it use?
23 features, including purpose, slot, price-tier gap versus the build, performance tier, balance, cooling margin, PSU headroom/rating and VRAM. The top ones are budget slack (19%), slot (14%), price-tier gap (13%) and performance tier (11%).

Q Where did the training data come from?
53,985 rule rows: random partial builds from the real catalog, labelled by expert rules for 5 purposes and several budgets. 739 real rows: saved builds, orders and POS sales, where the part the customer chose counts as good. Real rows are weighted 5×.

Q 99% accuracy is suspicious. Is it overfitting?
TRAP
It's cross-validated by build, so each score comes from builds the model never saw. It's high because most labels come from rules, which trees learn easily. On real rows alone it's about 47%, because only the one part the customer picked counts as “right”. That's why we report Hit@3 (65%) as the fair measure.

Q Does the model improve over time?
Yes. Every night at 02:00 it rebuilds the dataset from the database (read only) and retrains. The new model goes live only if the row count is ≥ 90% of the last run and accuracy is ≥ 0.90; otherwise the old model stays.

Q Why does PHP run the forest, not Python?
DEEP
The trained trees are exported to `forest.json`, and PHP walks them directly. No extra server is needed, and recommendations work even if Python is down.

Q Can it recommend a part that leaves no option for another slot?
No. A “dead-end” check refuses any part that would leave a required part with no compatible item in stock.

Q What is “Build it for me”?
Given a purpose and budget, it fills each empty slot in order, using a budget share per slot and the best-scoring compatible part.

Q What if a product description is wrong?
ADMIT
Compatibility relies on product text, so bad names give bad tags. The fix is storing specs as proper product columns.

Q How is PSU wattage estimated?
CPU 65 W + board 40 W + GPU 180 W + RAM 10 W + storage 15 W for the rule check; the recommender also looks at PSU headroom and rating.

10 · Database, testing and deployment

Q What are your main tables?
`users`, `products`, `orders` / `order_items` / `shipments`, `pos_sales` / `pos_sale_items`, `stock_movements` (stock ledger), `logs` (audit), `notifications`, `cart`, `wishlist`, `saved_builds`, `order_reviews`, `messages`, `site_settings`.

Q Show us normalization / relationships.
Orders reference users; order_items reference orders and products; shipments reference orders; sale items reference sales. Sale items copy the name and price at the time of sale, on purpose, so old receipts never change.

Q How did you test the system?
Syntax checks on every PHP file. Database logic tested in transactions that are rolled back afterwards. Role access tested with logged-in requests per role. UI tested with automated headless-browser runs (including simulated scans) and screenshots at desktop, tablet and phone widths. ML models evaluated with cross-validation and held-out test sets.

Q Do you have unit tests?
ADMIT
No automated test suite. Testing was scripted and manual as described. The ML side has its own test scripts (`test_intents.py`, `evaluate_cv.py`).

Q What if the database is down?
Visitors see a branded “can't connect” page. Technical details go only to the server log.

Q What if an AI service is down?
Primo shows “temporarily unavailable”. Without Groq it still answers with plain database sentences. The forecast shows a “waking up, retry” message. Build a PC still filters with rules if the model file is missing.

Q Can it scale to more branches?
TRAP
Not as is: stock is one number per product. Multi-branch needs a stock-per-branch table and a branch on each sale and order. The rest (roles, POS logic, models) carries over.

Q How are backups handled?
Supabase manages the hosted database and its backups. All schema changes are written as SQL migration files in `database/`.

11 · Limitations and future work

say these before they find them

LIMITATION	WHY	FUTURE WORK
Online payment is a placeholder	Real gateways need business verification	PayMongo (or similar), mark paid from its webhook
“Max failed attempts” setting not applied	Login uses a fixed 3	Read the setting in login.php
2FA not on the main login	TOTP code exists only in the old API	Enable TOTP for staff

Same stock thresholds for all products	Simpler rule for one branch	Per-product reorder level from the forecast
No suppliers table	Supplier = brand	Suppliers table + purchase orders
Compatibility from product text	No structured spec columns	Store socket/DDR/form/watts as columns
Online stock not reserved at order time	Deducted at completion	Reserve stock on payment
Free-tier AI hosting sleeps	Cost	Paid plan or scheduled warm-up
One live database, no test copy	Free plan	Staging database
Single branch, no courier API	Project scope	Branch stock table, Lalamove API tracking

12 · If the demo breaks

WHAT HAPPENS	WHAT TO SAY / DO
Forecast spins for a long time	“The forecast service is on a free host that sleeps; it takes about a minute to wake.” Show another module, then come back.
Primo says “temporarily unavailable”	The Python service is asleep or not started. Locally: `python predict_api.py` in `ml/primo`. Meanwhile, show a compatibility question; it doesn't need the SVM.
“Can't connect” page	Database or internet issue. Check Wi-Fi/hotspot; the page itself proves the error handling works.
Logged out mid-demo	That's the 15-minute idle timeout working as designed. Log in again.
Account locked during demo	That's the 3-try lockout. Unblock it from Admin → Manage Users.
Scanner not reading	Type the barcode in the scan field and press Enter (same path). Test codes: `400000000015`, `20000011`, `2000000000015`.
Activation e-mail slow	Gmail delivery can take a minute; use the Resend button, or demo with an already activated account.

Lines in *italics* are for your team to fill in (survey results, forecast metrics, naming). Everything else comes from the code and model files. Good luck!